

Manual de Mejores Prácticas de Seguridad para Super Apps Financieras

Cifrado, Autenticación y Control de Acceso

Versión 1.0 – Primer Entregable del Security Kit

Este manual se alinea con:

- **Ley 25.326** (Protección de Datos Personales) – Art. 9 (medidas técnicas y organizativas para confidencialidad e integridad) y Art. 10 (deber de secreto).
- **Comunicación BCRA “A” 7724** y texto ordenado de Requisitos Mínimos de Gestión y Control de Riesgos de Tecnología y Seguridad de la Información (enfocado en servicios digitales).
- **ISO 27001:2022** (controles del Anexo A: 8.24 Uso de criptografía, 8.5 Autenticación segura, 8.3 Restricción de acceso a la información, 5.17 Información de autenticación).

El objetivo es que equipos pequeños o startups fintech implementen controles básicos sin infraestructura compleja y realicen autoevaluaciones periódicas.

1. Mejores Prácticas en Cifrado (Cryptography)

Objetivo: Garantizar confidencialidad e integridad de datos sensibles (datos de clientes, transacciones, credenciales).

Requisitos clave

- Cifrar datos en tránsito (TLS 1.3 mínimo).
- Cifrar datos en reposo según clasificación (AES-256 o equivalente).
- Gestionar claves de forma segura (nunca hardcodeadas, rotación periódica).

Controles recomendados (BCRA + ISO)

- Clasificar información (confidencial, interna, pública).
- Usar algoritmos aprobados (no MD5/SHA-1).
- Proteger backups con cifrado.

Guía paso a paso para cifrado de datos

1. Clasificar datos (ej.: datos de cuenta = confidencial).
2. En tránsito: Configurar HTTPS/TLS 1.3 en servidores y APIs (Let's Encrypt gratis).
3. En reposo:
 - Bases de datos → Transparent Data Encryption (TDE) en PostgreSQL/MySQL o AWS RDS encryption.
 - Almacenamiento de archivos → AES-256 con librerías como libsodium o AWS KMS (capa gratuita).
4. Claves → Usar gestor como HashiCorp Vault (open source), AWS Secrets Manager o Infisical (gratuito para startups).
5. Rotar claves cada 12 meses o ante incidente.

2. Mejores Prácticas en Autenticación

Objetivo: Verificar identidad de usuarios y prevenir accesos no autorizados.

Requisitos clave (BCRA sección 5.7.2)

- Autenticación multifactor (MFA) obligatoria para accesos a activos críticos, billeteras digitales y operaciones de alto riesgo.
- Factores: algo que se sabe (contraseña), se tiene (OTP/app), se es (biométrico).
- Secreto memorizado: longitud mínima 12 caracteres, hash seguro (bcrypt/Argon2), límite de intentos.

Guía paso a paso para configurar MFA

1. Elegir proveedor (recomendado para startups):
 - Auth0 (plan gratuito hasta 7.000 usuarios activos).
 - Firebase Authentication (gratis con Google).
 - Keycloak (open source, self-hosted).
2. Configurar en la app móvil/web:
 - En registro/login → Activar MFA obligatorio para transacciones > umbral o primer login.
 - Métodos: TOTP (Google Authenticator), WebAuthn (biometría + hardware key), SMS como fallback (evitar si posible por SIM-swapping).
3. Implementar adaptive MFA (basada en riesgo): IP nueva, dispositivo nuevo → requerir factor adicional.
4. Almacenar solo hash del secreto (nunca el OTP en claro).
5. Probar flujo: usuario → ingresa usuario/contraseña → recibe código/app push → verifica → acceso concedido.

3. Mejores Prácticas en Control de Acceso

Objetivo: Aplicar principio de menor privilegio y segregación de funciones.

Controles clave (ISO 8.3 + BCRA 5.7.2)

- Role-Based Access Control (RBAC).
- Revisión periódica de privilegios (cada 6 meses).
- Revocación automática de accesos inactivos (30 días).
- Logs de acceso auditables.

Implementación básica

- Usar IAM de cloud (AWS IAM, Google IAM) o librerías como Casbin (open source).
- Cuentas de servicio → tokens de corta duración (JWT con expiración 1h).
- Entornos: separar dev/staging/prod con accesos distintos.

4. Plantillas de Políticas

Plantilla 1 – Política de Contraseñas (basada en BCRA 5.7.2 y ISO 5.17)

- Longitud mínima: 12 caracteres – Máxima que recomendamos es 20 caracteres.
- Complejidad: al menos una mayúscula, minúscula, número y símbolo.
- No permitir contraseñas comunes o basadas en información personal.
- Vigencia máxima: 90 días (o sin vencimiento si se usa MFA + passwordless).
- Bloqueo tras 5 intentos fallidos (30 min).
- Hashing: Argon2id o bcrypt (work factor ≥ 12).
- Prohibido reutilizar últimas 12 contraseñas.

Plantilla 2 – Política de Gestión de Credenciales

- Credenciales nunca en código fuente (usar .env + gitignore).
- Rotación automática cada 90 días para claves API.
- Almacenamiento: gestor de secretos (Vault, AWS Secrets Manager, Infisical).
- Acceso a credenciales: solo personal autorizado + MFA + logging.
- Revocación inmediata ante salida de empleado o sospecha de compromiso.

5. Herramientas de Escaneo Automático de Vulnerabilidades de Bajo Costo

Recomendadas para startups (gratuitas o freemium)

- **OWASP ZAP** → Escaneo dinámico de aplicaciones web/API (DAST). Ideal para CI/CD.
- **OpenVAS / Greenbone** → Escáner de vulnerabilidades de red completo (similar a Nessus).
- **Trivy** → Escaneo de contenedores, imágenes Docker y dependencias (rápido y ligero).
- **OWASP Dependency-Check** → Detecta vulnerabilidades en librerías Java/.NET/Python/etc.
- **Snyk** (plan gratuito) → Escaneo de código abierto y secretos.
- **Nikto** → Escaneo rápido de servidores web.
- **TruffleHog** → Búsqueda de secretos expuestos en repositorios Git.